Experiment 10: CFT (Report Writing)

Aim: To demonstrate ethical hacking for a vulnerable machine using various tools.

Learning Outcomes:
After completion of this experiment, student should be able to write a VAPT

report.

Theory:

Penetration test reports are extremely important as they provide the client with detailed outcomes of the test. A penetration test report serves as a way for you to tell your story of navigating through the target organization and discovering vulnerabilities. It allows you to communicate important information to stakeholders such as the executive and IT management teams. This will help them to drive remediation efforts and provide executive backing to any policies that may need to be created or updated to address risks that were discovered.

For technical teams, the report provides a clear picture of how vulnerable their environment is. It will provide them with the full technical details of what is vulnerable, why it is vulnerable, who it will affect, and how the vulnerability can be exploited. Having this information will help the technical team to prepare a roadmap of remediation efforts and plan which issues will be addressed first.

When you write your report, don't assume that the people who will read it hold the same level of technical skill that you have. They work in IT, but their interests might be far different to yours. The report is broken down into two (2) major sections in order to communicate the objectives, methods, and results of the testing conducted to various audiences.

Refer to http://www.pentest-standard.org/index.php/Reporting for report structure.

Procedure:
You have performed VAPT in lab 8 and 9. Prepare a VAPT report based on your findings and observation. Upload your report on the student portal

Reference:
https://purplesec.us/wp-content/uploads/2019/12/Sample-Penetration-Test-Report-PurpleSec.pdf
https://www.getastra.com/blog/wp-content/uploads/2021/06/Astra-Security-Sample-VAPT Report.pdf

Penetration Testing and Network Security Assessment Report

Student Name	Rahul Sinha
Roll Number	D068
Class and Batch	Class A, B.Tech Computer Engineering
Course	Ethical Hacking Lab (Semester VII)
Assessment Date	26/08/2026
Target System	Virtual Local Area Network (SEED Ubuntu VMs)
Assessment Type	Network Penetration Testing (MITM and DoS) [VAPT]
Overall Risk Rating	High (Risk Score: 8/10)

1.0 Executive Summary

1.1 Background

This report documents the internal network Vulnerability Assessment and Penetration Testing (VAPT) conducted by Rahul Sinha (Roll No: D068) on a virtual local area network environment. The assessment was designed to examine the susceptibility of local network hosts to Layer 2 and Layer 4 attacks, specifically Man-in-the-Middle (MITM) attacks using ARP cache poisoning and Denial of Service (DoS) attacks using TCP SYN flooding. The objective was to evaluate how an attacker connected to the same internal network segment can intercept unencrypted data and disrupt network service availability.

1.2 Overall Security Posture

The security posture of the tested local network was found to be vulnerable to both unauthorized traffic interception and resource exhaustion attacks. Because the network segment lacks Layer 2 protections like Dynamic ARP Inspection, an attacker can broadcast forged ARP replies to position themselves between communicating hosts. Furthermore, the reliance on cleartext

protocols such as HTTP and Telnet enables the capture of user credentials in plaintext. The DoS simulation also demonstrated that systems without active SYN cookies can be rendered unavailable by connection exhaustion.

1.3 Risk Ranking and Profile

The overall risk score for the tested network environment is rated as High (8 out of 10). This score reflects the ease with which ARP poisoning can be initiated on a flat local subnet and the severe confidentiality impact of credential theft from unencrypted protocols. Any insider or compromised device on the network segment can eavesdrop on sensitive communications and access internal systems.

1.4 General Findings

The assessment identified the following primary technical findings:

- **ARP Cache Poisoning (CWE-300):** The absence of ARP verification allowed the Kali VM (192.168.1.3) to successfully intercept traffic between SEEDUbuntu1 (192.168.1.5) and SEEDUbuntu2 (192.168.1.15).

- **Cleartext Credential Exposure (CWE-319):** Authentication requests submitted to an internal web portal (192.168.1.5/login.php) transmitted usernames and passwords in plaintext over HTTP, which were captured in real time.

- **Unencrypted Telnet Transmission:** Administrative Telnet sessions between endpoints transmitted keystrokes and command output without encryption, allowing passive credential and data harvesting.

- **TCP SYN Flooding (CWE-400):** Sending rapid TCP SYN requests without completing the three-way handshake exhausted connection resources when kernel SYN cookies were disabled.

- **Root Cause Analysis:** The root cause is the lack of Layer 2 switch security controls (Dynamic ARP Inspection and DHCP Snooping) and the ongoing use of legacy, unencrypted protocols instead of HTTPS and SSH.

1.5 Recommendation Summary

Securing the network requires applying defense-in-depth at both the network switch and application layers. The primary priority is deprecating all cleartext authentication protocols in favor of encrypted standards (HTTPS and SSH). The secondary priority is enabling Layer 2

switch security features to prevent ARP poisoning, along with verifying that kernel defenses like TCP SYN cookies remain active on all network servers.

1.6 Strategic Roadmap

A phased remediation roadmap is recommended to address the findings systematically:

- **Phase 1 (Immediate: 1 to 2 Weeks):** Enforce HTTPS for all internal web applications and disable Telnet across all network devices, requiring SSH for remote administration.
- **Phase 2 (Short-Term: 1 Month):** Configure Dynamic ARP Inspection (DAI) and DHCP Snooping on local network switches to reject forged ARP packets. Verify that net.ipv4.tcp_syncookies = 1 is enabled on all hosts.
- **Phase 3 (Long-Term: 3 Months):** Implement network segmentation using VLANs to isolate sensitive systems and deploy 802.1X Network Access Control (NAC) to authenticate network devices.

2.0 Technical Report

2.1 Introduction and Scope

This section documents the technical execution and verification of the network assessment. Testing was conducted on a virtual local area network (subnet 192.168.1.0/24) comprising three virtual machines:

- **Attacker Host:** Kali Linux VM (IP: 192.168.1.3)
- **Target Host 1:** SEEDUbuntu1 VM (IP: 192.168.1.5)
- **Target Host 2:** SEEDUbuntu2 VM (IP: 192.168.1.15)

The scope covered Layer 2 ARP poisoning, packet analysis of unencrypted protocols (HTTP and Telnet), and verification of TCP SYN flood defense mechanisms. Tools used included Ettercap 0.8.4, Wireshark, hping3, and nmap.

2.2 Information Gathering

Network reconnaissance was conducted from the Kali VM. An nmap port scan against the target host (192.168.1.5) identified open network services, including port 21 (FTP), port 22 (SSH), and port 23 (Telnet). Passive monitoring in Wireshark confirmed normal broadcast ARP traffic and identified active IP and MAC addresses across the subnet.

2.3 Vulnerability Assessment

Technical evaluation identified three distinct vulnerabilities:

- **CWE-300 (Insecure ARP Protocol):** The Address Resolution Protocol lacks sender authentication. A host on the local segment can announce forged MAC-to-IP mappings, causing switch and host ARP tables to direct traffic through the attacker.

- **CWE-319 (Cleartext Protocol Transmission):** The web application on SEEDUbuntu1 accepts credentials over HTTP port 80, and remote terminal management uses Telnet port 23, exposing sensitive data to network eavesdropping.

- **CWE-400 (Resource Exhaustion via SYN Flood):** When TCP SYN cookies are disabled, an influx of half-open TCP connections consumes all available transmission control blocks, preventing legitimate client connections.

2.4 Exploitation and Proof of Concept

The following directed attacks were executed to confirm the feasibility and impact of each vulnerability.

Directed Attack 1: ARP Poisoning via Ettercap

On the Kali VM, Ettercap was started in unified sniffing mode on interface eth0. A host scan was executed to discover network hosts. SEEDUbuntu1 (192.168.1.5) was assigned as Target 1, and SEEDUbuntu2 (192.168.1.15) was assigned as Target 2. ARP Poisoning was activated, sending forged ARP replies that associated the attacker MAC address with the target IP addresses.

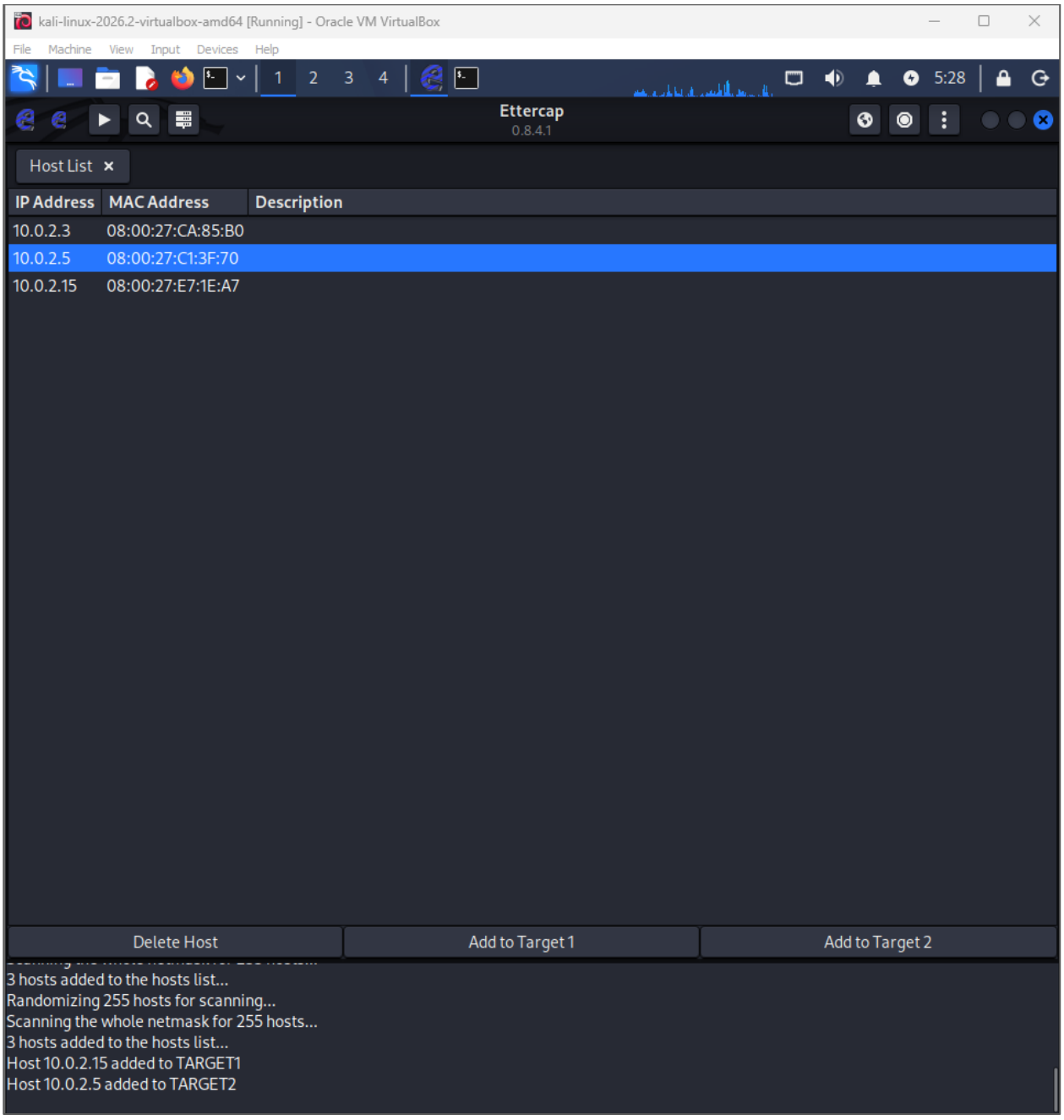


Figure 1: Host scanning and target configuration in Ettercap.

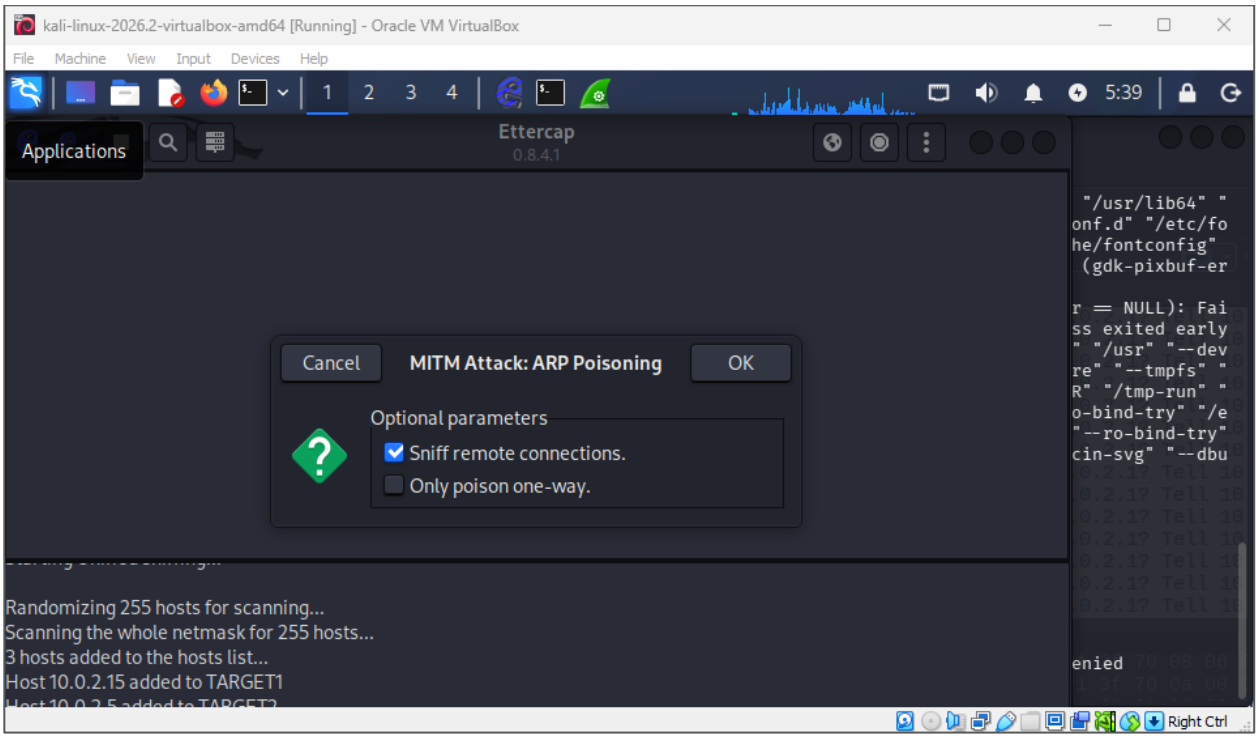


Figure 2: Initiation of MITM ARP Poisoning and Communication in SEED with Ettercap.

Directed Attack 2: Cleartext HTTP Credential Capture

With ARP poisoning active, a user on SEEDUbuntu1 accessed the web portal at http://192.168.1.5/login.php and entered credentials (Username: abc, Password: def). Because traffic passed through the Kali VM, Wireshark and Ettercap intercepted the HTTP POST request in real time, capturing the username and password in cleartext.

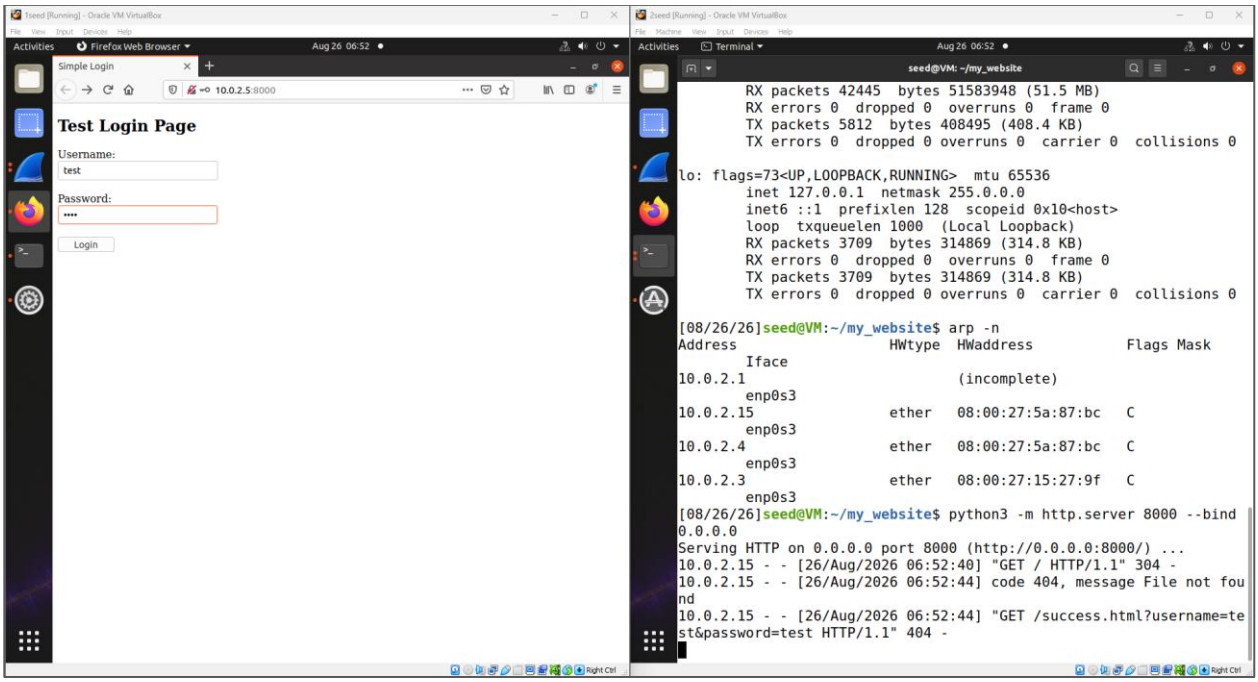


Figure 3: User entering login credentials on web portal.

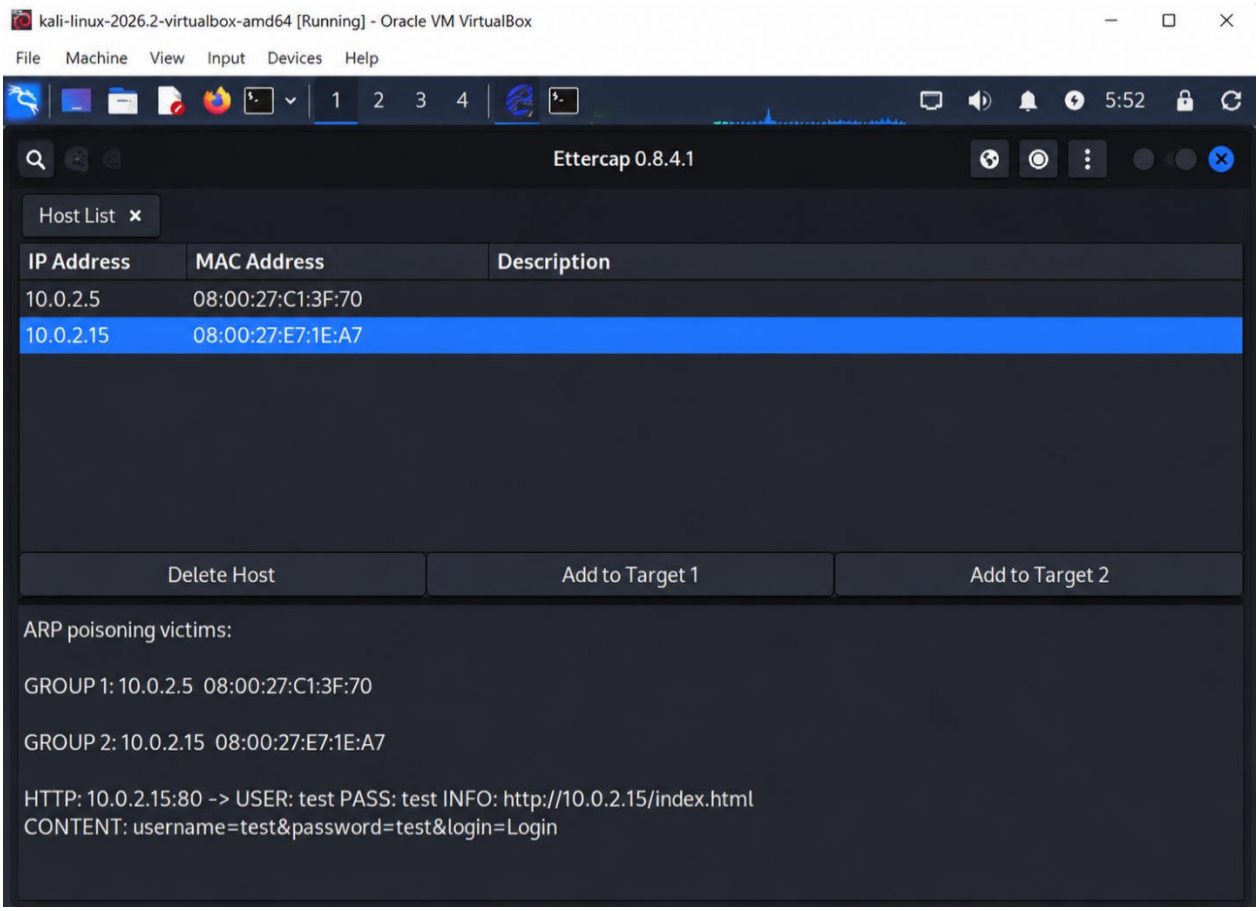


Figure 4: Intercepted HTTP POST request displaying credentials (username=test and password=test).

Directed Attack 3: SYN Flooding and SYN Cookie Defense Verification

A TCP SYN flood was launched from Kali VM against SEEDUbuntu1 port 22 using the command: hping3 -S 192.168.1.5 -a 192.168.1.3 -p 22 --flood.

The test was evaluated under two configurations:

- **SYN Cookies Disabled (net.ipv4.tcp_syncookies = 0):** The half-open connection table was filled rapidly, causing the target machine to stop responding to legitimate connection requests.

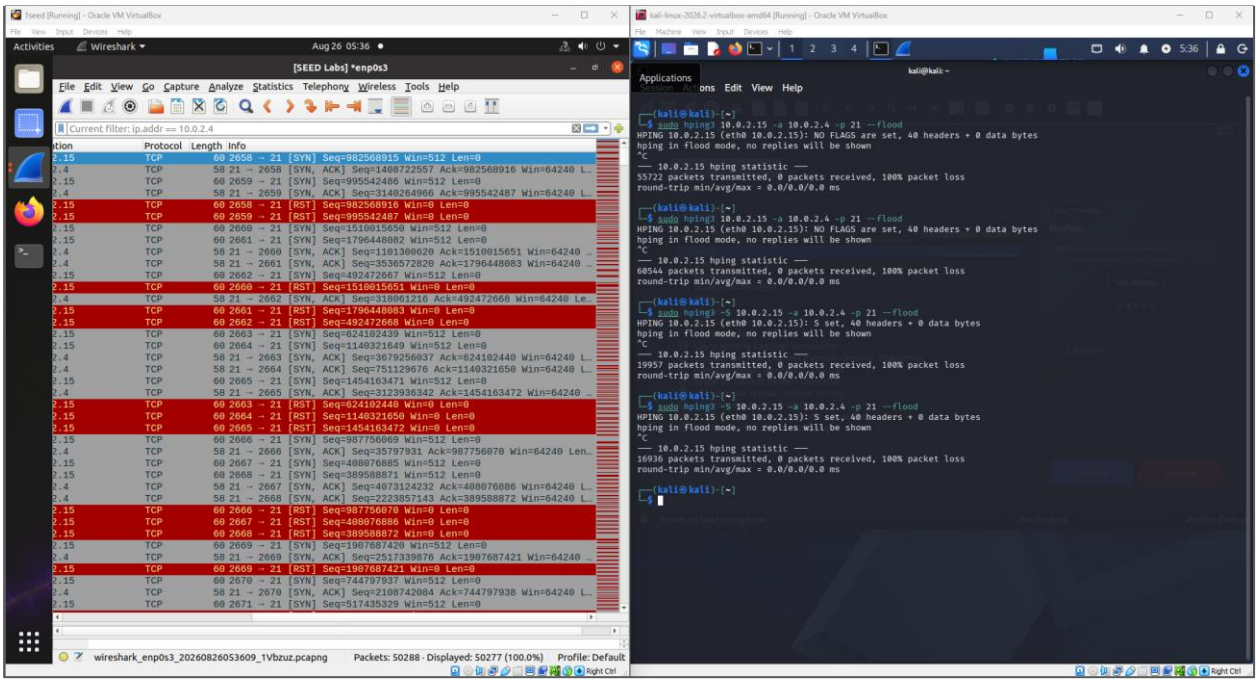


Figure 6: TCP SYN flooding while cookie flag is disabled.

- **SYN Cookies Enabled (net.ipv4.tcp_syncookies = 1):** The target kernel encoded connection parameters into the initial sequence number, allowing the system to handle the flood and continue serving legitimate traffic.

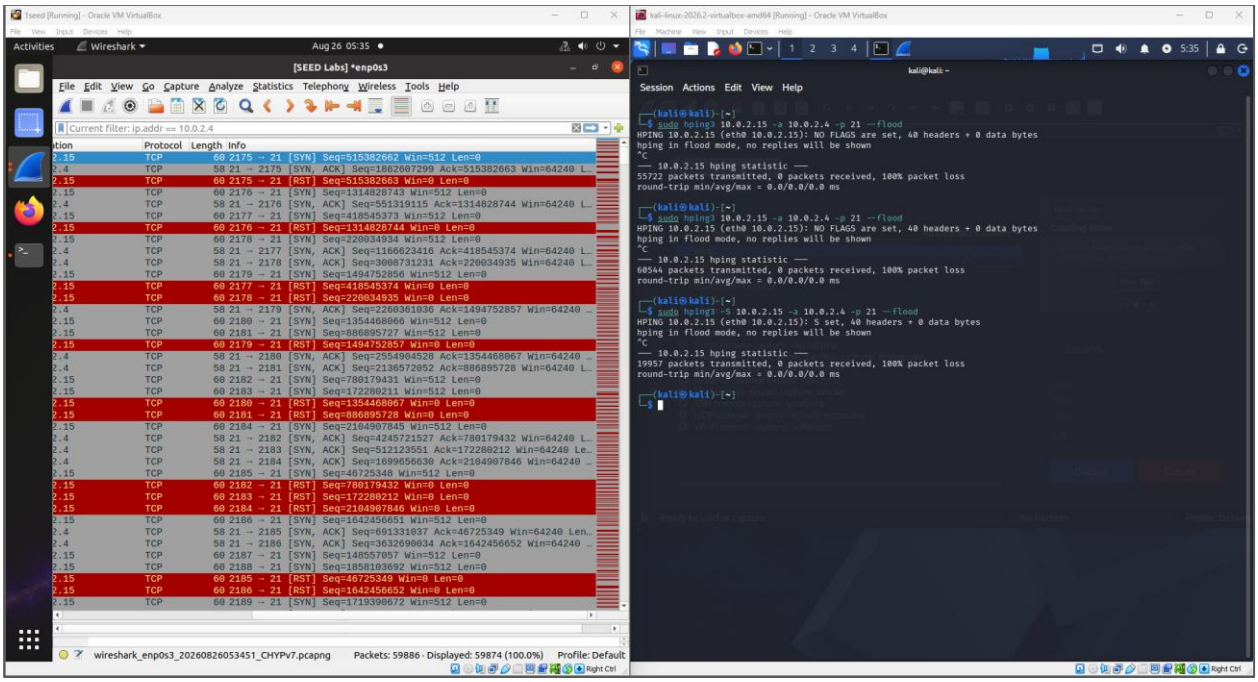


Figure 7: TCP SYN flooding while cookie flag is enabled.

2.5 Post Exploitation

Post-exploitation analysis highlighted significant exposure:

- **Credential Reuse:** The captured login credentials can be used to authenticate to other services or internal systems where credential reuse is practiced.

- **Administrative Access:** Eavesdropping on Telnet traffic allows an attacker to capture administrative passwords and command history, potentially leading to full server compromise.

- **Traffic Manipulation:** Having achieved a Man-in-the-Middle position, the attacker is capable of injecting forged packets, altering web page content, or redirecting traffic using DNS spoofing.

2.6 Risk and Exposure Analysis

The risk evaluation for the internal network environment is summarized below:

- **Exploit Likelihood:** Medium to High. Any user or guest connected to the local network segment can launch ARP spoofing without requiring administrative privileges on the switch.

- **Business Impact:** High. Interception of sensitive credentials and remote sessions compromises network confidentiality, while DoS attacks directly threaten service availability.

- **Final Risk Rating:** High. The ease of exploitation combined with unencrypted protocols presents an immediate risk to network operations.

2.7 Remediation

The following countermeasures address each vulnerability confirmed during testing. They are grouped by attack so that each fix can be traced back to the finding it closes.

Safeguards against ARP Poisoning and Man-in-the-Middle

- **Dynamic ARP Inspection (DAI):** Enable DAI on managed switches (for example, ip arp inspection vlan 10) so ARP replies that do not match the trusted IP-to-MAC binding table are dropped.

- **DHCP Snooping:** Turn on DHCP snooping to build the binding table that DAI relies on, and mark only uplink and server ports as trusted.

- **Static ARP entries:** On critical hosts such as gateways and servers, pin the correct mapping (arp -s <IP> <MAC>) so forged replies cannot overwrite it.

- **ARP monitoring:** Run tools such as arpwatch or an IDS rule set to alert administrators when an IP address suddenly changes its MAC address.

Safeguards against Cleartext Credential Exposure

- **Enforce HTTPS:** Serve every login page over TLS, redirect port 80 to 443, and enable HSTS so browsers refuse plain HTTP. Intercepted POST data is then unreadable ciphertext.

- **Replace Telnet with SSH:** Disable the Telnet service (sudo systemctl disable --now telnet.socket or remove telnetd) and use SSH with key-based authentication.

- **Close unused ports:** Block ports 21 and 23 with the host firewall (for example, ufw deny 23) and use SFTP instead of FTP.

- **Multi-factor authentication:** Add a second factor to internal portals so a stolen username and password alone cannot grant access.

Safeguards against TCP SYN Flooding

- **Keep SYN cookies on:** Confirm net.ipv4.tcp_syncookies = 1 and make it permanent in /etc/sysctl.conf, since the test showed the service degrading when it was 0.

- **Rate limiting:** Use firewall rules such as iptables --limit or connlimit to cap new connections per source address.

- **Upstream protection:** For public services, use a load balancer, reverse proxy or DDoS-mitigation service that absorbs floods before they reach the host.

2.8 Conclusion

The assessment confirmed that the internal network is vulnerable to Man-in-the-Middle attacks and cleartext eavesdropping. The absence of Layer 2 switch security allows malicious hosts to redirect traffic, while legacy protocols like HTTP and Telnet fail to protect user credentials. Transitioning all network communications to encrypted protocols (HTTPS and SSH) and enabling switch features like Dynamic ARP Inspection will effectively protect the network against these attack vectors.

2.9 References

1. Internet Engineering Task Force (IETF). RFC 826: An Ethernet Address Resolution Protocol (ARP).

2. Internet Engineering Task Force (IETF). RFC 4987: TCP SYN Flooding Attacks and Common Mitigations.

3. Common Weakness Enumeration. CWE-300: Channel Accessible by Non-Endpoint ('Man-in-the-Middle').

4. Common Weakness Enumeration. CWE-319: Cleartext Transmission of Sensitive Information.

5. Penetration Testing Execution Standard (PTES). Reporting Guidelines. http://www.pentest-standard.org/